

21EIE552T – CYBERSECURITY IN INDUSTRIAL AUTOMATION

Dr.G.Y.Rajaa Vikhram
Assistant Professor/EIE
SRMIST

Course Learning Rationale (CLR):	The purpose of learning this course is to:
CLR-1 :	<i>Introduce the basic knowledge in industrial automation and control systems</i>
CLR-2 :	<i>Know the basic concepts of information system security for industrial control systems</i>
CLR-3 :	<i>Understand the difference between IACS and IT paradigms</i>
CLR-4 :	<i>Impart the adequate information about risk management for IACS</i>
CLR-5 :	<i>Introduce the security methodologies and approaches for IACS</i>
CLR-6 :	<i>Understand the need of cybersecurity for different industrial applications</i>

Course Outcomes (CO):	At the end of this course, learners will be able to:
CO-1 :	Describe the basic concepts of industrial automation and control systems
CO-2 :	Illustrate any application with add-on security features in industrial control systems
CO-3 :	Select the software with IT paradigms for IACS
CO-4 :	Analyze the risk management approach for IACS
CO-5 :	Examine the security methodologies for industrial systems
CO-6 :	Design cybersecurity resilient algorithm for selective applications

Information System Security Technology
12
Information System Security Fundamentals
Terminologies
Threat Matrix
Type and Classes of Attack
Additional System Security
Policies, Standards
Tutorial: 1 – Cyber system simulation
Guidelines and Procedures
Malicious Codes and Attacks
Firewalls

Cryptography
Digital Signatures
Attacks against Cryptosystems
Tutorial: 2 – Security assessment
Virtual Private Network
IPsec
Transport mode
Tunnel mode
Secure sockets layer
Physical and economic damage
Tutorial: 3 – Cyber and Physical security

Overview:

- Chapter 1 provided a review of some fundamental industrial automation and control system concepts, assuming that the reader has some familiarity with these systems. Because this subject is focused on the security of industrial automation and control systems.
- Chapter 2 will delve into the details of information system security in order to provide a basis for developing effective security approaches for industrial automation and control systems. The field of information system security has evolved over decades and is an abundant source of valuable knowledge and techniques that have been proven over time.

- By taking into account the unique characteristics of industrial automation and control systems, the technology of information system security can be adapted and tailored to provide effective security for the many types of industrial automation and control applications.

Information System Security Fundamentals

- Information system security is defined as comprising the three basic elements of confidentiality, integrity, and availability, or C-I-A. These three concepts form the C-I-A triad, as shown in Figure 2-1.
- Additional complementary elements that support information system security are identification, authentication, authorization, accountability, auditing, and nonrepudiation. These important topics are summarized in the following sections.

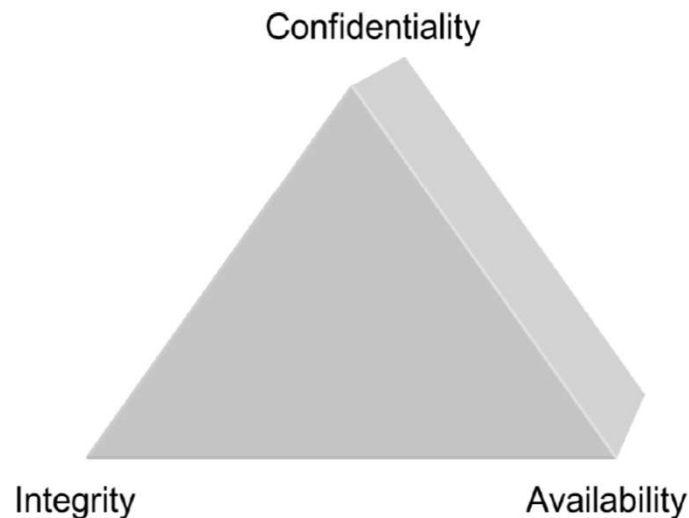


Figure 2-1. The C-I-A triad

Confidentiality

- Confidentiality refers to protecting documents, messages, computer files, and so on from being disclosed, either intentionally or unintentionally, in an unauthorized manner.
- Examples of loss of confidentiality are an unauthorized individual intercepting and reading a message sent across a network or the revelation of a company's trade secret. Confidentiality is related to privacy of information in that it is concerned with the unauthorized disclosure of sensitive information.

Integrity

- Integrity (as applied to data) is concerned with the unauthorized modification of data, whether by an authorized or an unauthorized individual or process.
- If a message is intercepted, its contents are changed, and it is then forwarded to a receiver, its integrity has been violated.

Availability

Availability is a measure of the ability of an authorized person or process to have prompt and reliable access to computational resources when needed. For example, availability would be compromised if an individual is prevented from conducting an online financial transaction because the financial organization's web site is down.

Identification

Identification is the act of professing an identity to a system or process. A typical example of identification is a computer user typing in a user ID when logging onto a computer system.

Authentication

Authentication is the act of verifying an identity and confirming that an entity is what it professes to be. An **example** of authentication is verifying that a logon user ID actually belongs to the claimed user.

Authorization

When identification and authentication are completed, a user or process can be granted access privileges to specific computer information or resources. Different individuals or processes can be granted different levels of authorization, depending on the sensitivity of the information being accessed and the level of the rights granted to those individuals or processes to access the information.

Accountability

Accountability is the ability to identify an individual and to hold that individual responsible for his or her actions. Tools, such as audit logs, can help in determining accountability and uncover activities that were conducted by individuals or processes.

Auditing

Auditing is the act of reviewing logs or records at specified intervals to determine if violations of system security have occurred. Typical audit logs include information such as where and when a transaction occurred and who conducted the transaction. A companion endeavor to auditing is monitoring, which refers to a continuing activity, such as intrusion detection on a network or host computer.

Nonrepudiation

Nonrepudiation in digital systems refers to ensuring that the sender of a message or contract cannot later deny sending the message or contract and that, conversely, a receiver to whom the message was sent cannot deny receiving the message.

Digital signatures are used to implement nonrepudiation in electronic transactions, and they will be discussed later in this chapter.

Related Terminology

In addition to the [above principles](#), **four related terms** that appear [throughout the information security landscape](#) and that should be understood by all involved with protecting computer systems and networks are:

- Asset – An organization’s important resource, whose loss or compromise could negatively impact confidentiality, integrity, or availability and could also result in financial loss. Therefore, an asset should be protected from attack or compromise.
- Threat – As defined by NIST SP 800-53¹: “Any circumstance or event with the potential to adversely impact agency operations (including mission, functions, image, or reputation), agency assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.”

- Safeguard – A security control or countermeasure designed to mitigate the risk associated with a specific threat or group of threats.
- Vulnerability – The absence or weakness of a safeguard. According to NIST 800-53, vulnerability is “weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.”

Vulnerability can be decreased by applying controls that will mitigate the effect of an attack. Controls can be partitioned into the following categories:

- Corrective controls minimize the effect of an attack and the degree of resulting damage.
- Detective controls discern if attacks have occurred or are occurring, and initiate control measures.
- Deterrent controls reduce the potential for an attack to occur.
- Preventive controls prevent a threat from exploiting a vulnerability.

- Threat matrix is used to prioritize which controls to apply and where to apply them.
- The threat matrix plots the impact of an attack would have if it is successful versus the likelihood that the attack will occur.
- In this way, resources can be applied to mitigate the threats with the highest impact and the highest likelihood of occurrence.
- The objective of this activity is to move all threats into the low impact and low likelihood of occurrence area, as shown in Figure 2-2.

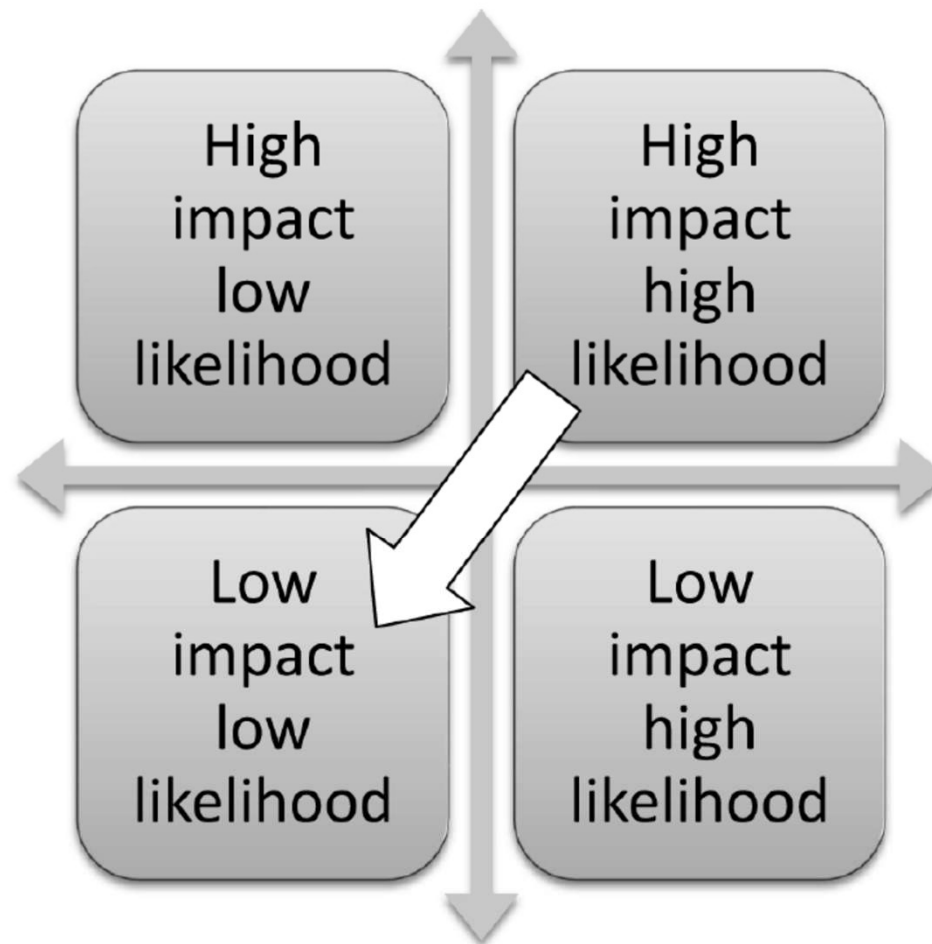


Figure 2-2. A threat matrix

Types and Classes of Attack

The Information Assurance Technical Framework (IATF) document 3.1,² sponsored by the National Security Agency (NSA), identifies the following types of attacks:

- Passive
- Active
- Close-in
- Insider
- Distribution

These attacks and their description are summarized in [Table 2-1](#).

Table 2-1. Types of Attacks

Attack	Description
Passive	Passive attacks include traffic analysis, monitoring of unprotected communications, decrypting weakly encrypted traffic, and capture of authentication information (such as passwords). Passive attacks can result in disclosure of information or data files to an attacker without the consent or knowledge of the user. Examples include the disclosure of personal information such as credit card numbers and medical files.
Active	Active attacks include attempts to circumvent or break protection features, introduce malicious code, or steal or modify information. These attacks may be mounted against a network backbone, exploit information in transit, electronically penetrate an enclave, or attack an authorized remote user during an attempt to connect to an enclave. (An enclave is collection of computing environments connected by one or more internal networks under the control of a single authority and security policy, including personnel and physical security.) Active attacks can result in the disclosure or dissemination of data files, denial of service, or modification of data.

Close-In	Close-in attack consists of individuals, not normally insiders, attaining close physical proximity to networks, systems, or facilities for the purpose of modifying, gathering, or denying access to information. Close physical proximity is achieved through surreptitious entry, open access, or both.
Insider	Insider attacks can be malicious or nonmalicious. Malicious insiders intentionally eavesdrop, steal, or damage information, use information in a fraudulent manner, or deny access to other authorized users. Non-malicious attacks typically result from carelessness, lack of knowledge, or intentional circumvention of security for such reasons as “getting the job done.”
Distribution	Distribution attacks focus on the malicious modification of hardware or software at the factory or during distribution. These attacks can introduce malicious code into a product, such as a back door to gain unauthorized access to information or a system function at a later date.
[Source: IATF Document 3.1, September 2002.]	

Additional System Security Concepts

In industrial automation and control systems as well as in information technology systems, it is important that the computer resources, networks, and associated equipment operate reliably, efficiently, and securely in performing the actions for which they were designed. A number of useful principles for designing and implementing secure IT systems have evolved and are important tools that can be applied to industrial automation and control systems. The following principles were delineated in a 1974 paper by Saltzer and Schroeder³:

- Complete Mediation
- Defense in Depth
- Economy of Mechanism
- Fail Safe
- Least Common Mechanism
- Least Privilege
- Leveraging Existing Components
- Open Design
- Psychological Acceptability
- Separation of Duties
- Weakest Link

The fundamental characteristics of these principles are summarized as follows:

Complete Mediation

Complete mediation requires that when an entity (a user or process) requests access to an object, such as a file or document in a computer system, the entity must go through a valid authorization process that cannot be circumvented.

Defense in Depth

Defense in depth is the act of establishing numerous layers of protection wherein a subsequent layer will provide protection if a previous layer is breached. NIST Special Publication 800-82⁴ defines a defense-in-depth architecture strategy as “the use of firewalls, the creation of demilitarized zones, and intrusion detection capabilities, along with effective security policies, training programs, and incident response mechanisms.” ANSI/ISA-99.00.01⁵ describes defense in depth as:

Provision of multiple security protections, especially in layers, with the intent to delay if not prevent an attack.

NOTE: Defense in depth implies layers of security and detection, even on single systems, and provides the following features:

Attackers are faced with breaking through or bypassing each layer without being detected.

A flaw in one layer can be mitigated by capabilities in other layers.

System security becomes a set of layers within the overall network security.

Economy of Mechanism

Economy of mechanism advances the concept that the design and implementation of defensive mechanisms should be straightforward, understandable, and not unnecessarily complex. Following these guidelines makes it easier to detect possible unauthorized access routes into the information system that could be used to acquire sensitive data or launch an attack.

Fail Safe

NIST SP 800-123⁶ explains the term *fail safe* as “If a failure occurs, the system should fail in a secure manner, i.e., security controls and settings remain in effect and are enforced. It is usually better to lose functionality rather than security.” Also, a fail-safe design should ensure that when a system recovers from a failure, it should recover in a secure state, where only authorized users have access to sensitive information.

Least Common Mechanism

Least common mechanism refers to having the least possible sharing of common security mechanisms among users or processes. Having many users sharing common security mechanisms can result in unknown or unauthorized access paths to sensitive data.

Least Privilege

In the principle of least privilege, a user or process is given the minimum amount of privileges, authorization, and so on, for the smallest amount of time that will permit the user or process to accomplish assigned tasks. Least privilege reduces the prospect of an individual or process having unauthorized access to sensitive information.

Leveraging Existing Components

Leveraging existing components is using the security mechanisms that are already in place in the most efficient and effective manner and to their maximum capabilities. This process can be accomplished by periodically reviewing the configuration of the security devices and optimizing their operational performance.

Open Design

Open design proposes that making designs and security approaches available to examination and scrutiny by a variety of parties will ensure that they are robust and are performing as required. The concept is that by making the designs available for review, any flaws or weaknesses can be exposed and corrected. The alternative to open design is to keep designs proprietary and confidential in the hope that by doing so they will be more secure from compromise. In almost all cases, open design results in more effective and reliable mechanisms.

Psychological Acceptability

Psychological acceptability is concerned with making the interface and interaction with access control mechanisms intuitive and easy for the user to understand and operate. In this way, the security controls will not be seen as interfering with the tasks at hand and as an obstacle to getting things done.

Separation of Duties

Separation of duties requires that functions, roles, or responsibilities should be distinct and independent from each other so that no entity can solely control sensitive operations. An example is that a person requesting or ordering an expensive item should not be the same person that signs the check for its purchase. Separation of duties forces multiple individuals to collude if they are going to commit fraud or obtain unauthorized access to data.

Weakest Link

As with any group of protection mechanisms, it is important to identify the weakest element in the group. Once the weakest link is identified, actions can be taken to bolster that element and mitigate any corresponding risk.

Policies, Standards, Guidelines, and Procedures

In addition to secure design principles, documents professing management's view of security and describing techniques of implementation are valuable tools in establishing the security of an organization. Four important categories of such tools are policies, standards, guidelines, and procedures.

Policies

In general terms, a policy is a statement of the intent of management for the organization, and compliance is mandatory. A policy is an important document because it provides top-down requirements for the organization and is necessary to protect sensitive information, prevent liability issues, and meet regulatory and legal requirements.

NIST SP 800-12⁷ defines the following three types of computer system security policies:

- Program policy – Creates an organization's computer security program
- Issue-specific policies – Addresses specific issues of concern to the organization
- System-specific policies – Protects a particular system through technical directives set forth by management

Table 2-2 summarizes the characteristics of the NIST policy types.

Table 2-2. NIST Policy Types

Policy Type	Description	Example
Program policy	High-level program policy	Senior-level management statement
Issue-specific policy	Addresses single issue	Email privacy policy
System-specific policy	Single-system directives	Router access control lists
[Source: NIST SP 800-12, <i>An Introduction to Computer Security: The NIST Handbook</i>]		

Standards

A standard details how specific methods must be applied in a consistent manner. For example, a standard for the types of information security controls that must be applied would ensure that all elements of the organization are incorporating technologies in a uniform manner.

Conformance to standards is normally compulsory.

Guidelines

Guidelines also detail methods to use to create secure information systems, but are considered to be recommendations and conformance is not compulsory.

Procedures

Procedures are step-by-step actions that must be taken to implement policies and standards. Procedures describe compulsory activities.

Malicious Code and Attacks

NIST SP 800-53⁸ defines malicious code as:

Software or firmware intended to perform an unauthorized process that will have an adverse impact on the confidentiality, integrity, or availability of an information system. A virus, worm, Trojan horse, or other code-based entity that infects a host. Spyware and some forms of adware are also examples of malicious code.

Malicious code (malware) is used in attacks against information systems and industrial automation and control systems. Some of the main types of attacks are reviewed in the following sections.

Viruses and Worms

ANSI/ISA-99.00.01-2007⁹ defines a virus as a “self-replicating or self-reproducing program that spreads by inserting copies of itself into other executable code or documents,” and a worm as a “computer program that can run independently, can propagate a complete working version of itself onto other hosts on a network and may consume computer resources destructively.” Note that a worm does not require other executable software to propagate but can move across networks to infect other hosts on its own.

Trojan Horse

A Trojan horse conceals additional code in a program that is used for a valid purpose. Then, the hidden code, which could be a virus, can perform

malicious acts. Trojan horses can be transmitted through emails or downloads from Web sites.

Logic Bomb

A logic bomb is a type of Trojan horse that does not execute until a preset condition is met, for example, at a specific time and date or when some activity is performed on the host computer.

Mobile Code

Software that is obtained or downloaded over a network from a remote source onto a local computer is known as mobile code. This mobile code can be used for valid applications or can contain a virus that could do harm to a computer system.

Back Door

In a back door attack, an individual attempts to gain access to a computer system by circumventing its protection mechanisms. An example is using a dial-up modem to call into a person's desktop computer and then accessing the organization's network through that computer.

Scanning

In scanning, an individual can locally or remotely connect to a computing system and obtain information about that system that can be used later in launching an attack. A scan can yield the following information:

- Open ports
- Services that are running
- Types of system software
- Domain names
- Existence of intrusion detection systems
- Protocols being used
- Existence of firewalls and perimeter devices

If a system is being scanned, this activity should be viewed as a prelude to a possible attack.

Man-in-the-Middle

A man-in-the-middle (MitM) attack focuses on the authentication protocol between a claiming party and a verifying party communicating with each other. For example, a claiming party can be asked to present and transmit particular credentials while the verifying party receives those credentials. In a successful attack, the attacker can intercept data between the two parties, modify it, and then pass it on without the knowledge of the sender or receiver.

Social Engineering

Social engineering uses “soft” methods to acquire sensitive information. Social engineering methods may be used to deceive individuals into revealing sensitive information, such as passwords or PIN numbers. Persuasive phone calls to an individual from an attacker impersonating someone in a position of authority, a phony email, or a fake call pretending to be from a help desk can elicit private information that can be used later against the organization. Social engineering threats can be minimized through effective awareness training and security policies.

Guessing Passwords

An attacker can use a variety of means to determine a user's password to gain entry to a computer system. Guessing, searching an area for passwords written on post-it notes, and looking over someone's shoulder are all methods that can be used to determine passwords. One approach, known as a dictionary attack, uses a dictionary of commonly used passwords to try to gain entry to a system.

Denial of Service/Distributed Denial of Service

A denial of service (DoS) attack is one that is designed to overwhelm a computer system's resources to the point where it can no longer perform its required functions. Thus, a DoS incident affects the availability of the computer system. In distributed denial of service (DDoS), the attacks on availability originate from multiple sources that work in concert to saturate a computer system's capabilities. In many instances, these sources are host computers on which the malicious DDoS software has been installed without the owner's knowledge.

Replay

In a replay attack, the perpetrator intercepts a message and saves it to be sent at a later time, when it seems to come from the original sender. A countermeasure to this attack is to attach a timestamp to the message at the time it was sent. Then, if the message is intercepted and sent at a later time, the timestamp will show it is an old message.

Dumpster Diving

In dumpster diving, an individual sorts through discarded material in a dumpster in hope of finding sensitive information that can be used later to attack an organization's computer system. In many cases, user's manuals, technical manuals, correspondence, organization charts, and other related material can provide valuable information to an attacker.

Firewalls

One of the important defenses against malware is a properly configured and implemented firewall. Firewalls implemented in industrial automation and control systems have to be “aware” of the special requirements and characteristics of such systems. The major types of firewalls are discussed in this section. NIST SP 800-41¹⁰ defines firewalls as “devices or programs that control the flow of network traffic between networks or hosts that employ differing security postures.” ANSI/ISA-99.00.01-2007 describes a firewall as:

an internetwork connection device that restricts data communication traffic between two connected networks.

NOTE: A firewall may be either an application installed on a general-purpose computer or a dedicated platform (appliance) that forwards or rejects/drops packets on a network. Typically firewalls are used to define zone borders. Firewalls generally have rules restricting which ports are open.

Firewalls are categorized as to their technical implementation and their architecture. The technical categories are packet filtering, stateful inspection, application, and application proxy. The architectural categories are screened-host, dual-homed host, and screened subnet firewall. These categories are reviewed in the following sections.

Packet Filtering Firewall

A packet filtering firewall resides at the network layer of the OSI model and determines which packets can be allowed to continue to their destination addresses by inspecting the packet source and destination addresses. It filters the packets based on firewall access control lists (ACLs), which specify the packets that can be sent to particular destination addresses or to specific application port destinations. Figure 2-3 illustrates a packet filtering firewall.

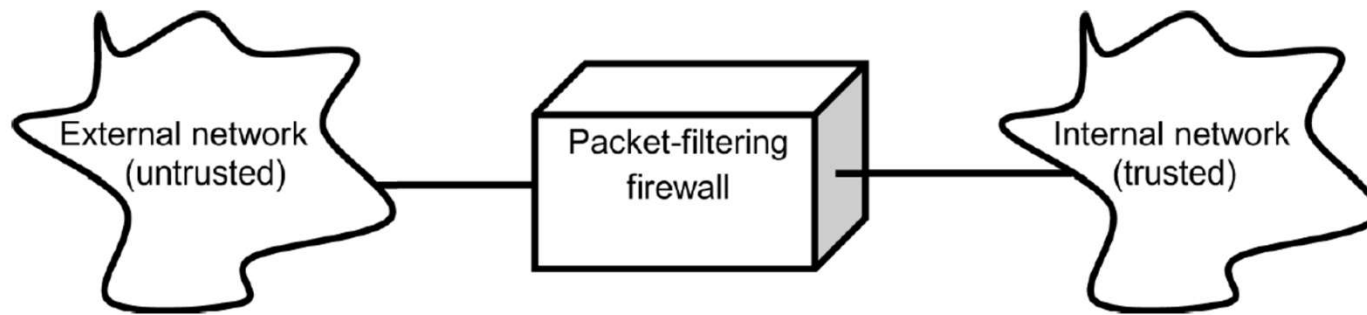


Figure 2-3. A packet filtering firewall

Stateful Inspection

A stateful inspection firewall improves on a packet filtering firewall by determining the state of incoming data connections at the network layer and blocking data packets that do not conform to the anticipated state. A state refers to one of the three primary states associated with TCP communications, namely, initiating the connection, establishing and using the connection, and terminating the connection. This information is contained in TCP headers and can indicate if a packet is not in its proper state. An attacker might place information in the header, indicating that the packet is in one state when it is actually in another. In this instance, the packet will not be passed through the firewall.

In addition to state information, the packet header also includes the source IP address, destination IP address, and port numbers. This information is stored in a dynamic state table for processing. An example of a state table is shown in [Table 2-3](#).

Table 2-3. Example State Table

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	192.0.2.71	80	Initiated
192.168.1.102	1031	10.12.18.74	80	Established
192.168.1.101	1033	10.66.32.122	25	Established
192.168.1.106	1035	10.231.32.12	79	Established
[Source: NIST SP 800-41 Revision 1, <i>Guidelines on Firewalls and Firewall Policy</i> , September 2009.]				

As an example of the firewall use of the state table, the source address (192.168.1.100) in the first row of the state table is an internal address behind the firewall and is initiating a connection to an IP address (192.0.2.71) outside of the firewall. This connection would have to be allowed under the firewall security policy.

Application Firewall

An application firewall performs what is sometimes referred to as deep packet inspection by incorporating stateful protocol analysis. This analysis is performed at the application layer of the OSI model and compares stored profiles of normal protocol usage against actual usage that might indicate malicious activity in an application. If malicious activity is detected, the firewall could inhibit specific connections to the information system. Potential malicious activity could include email with harmful attachments, unexpected command sequences, and the downloading of active mobile code.

Application-Proxy Gateway

An application-proxy gateway firewall serves as an intermediary between networks and serves to mask the source of a message. The application-proxy gateway operates at the application layer of the OSI model and provides a higher level of security at the expense of additional time being required for processing the data.

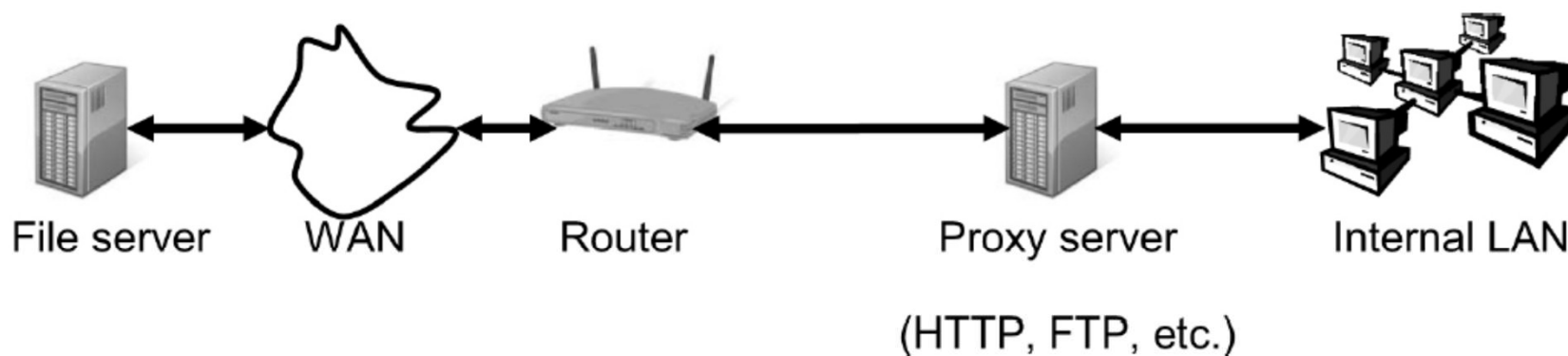


Figure 2-4. Application-proxy gateway

This type of firewall can be implemented by executing proxy software on a workstation that masks an internal network from external entities attempting to gain information about that network. Thus, the connection consists of communication between an internal computer and the proxy server and a connection between the proxy server and an external network. Most application proxy firewalls operate with HTTP. [Figure 2-4](#) is an example of an application-proxy gateway.

Screened-Host Firewall

A screened-host firewall uses a host to connect two networks together. This connection is accomplished through two network interface cards (NICs) that respectively connect to each one of the networks, with a screening router between the host and the untrusted network. This arrangement offers both proxy and routing capabilities. In this architecture, the firewall is facing outward toward the untrusted network and serves to protect the host and the trusted network. [Figure 2-5](#) illustrates a screened-host firewall.

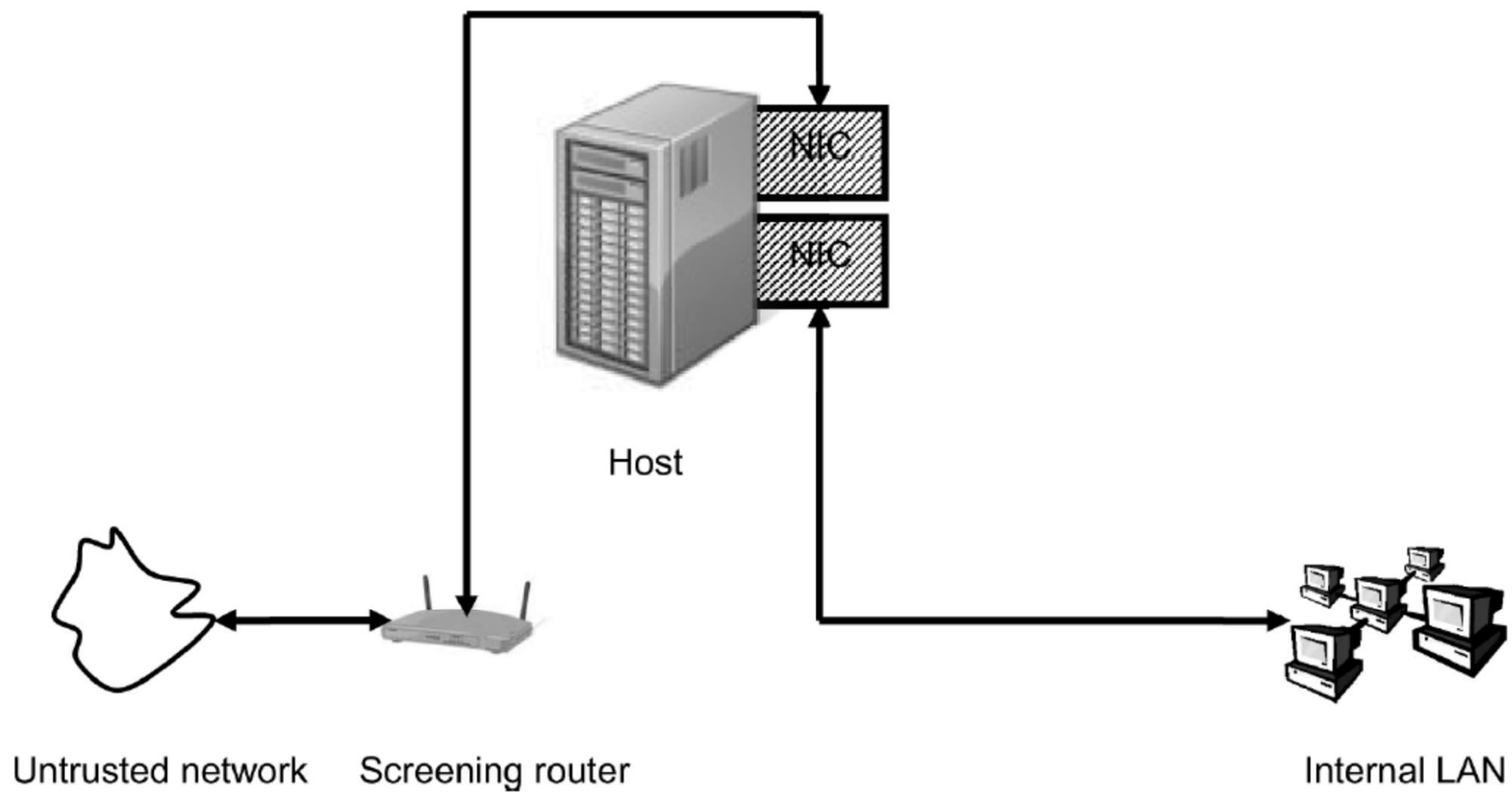


Figure 2-5. Screened-host firewall

Dual-Homed Host Firewalls

An architecture similar to the screened-host firewall is the dual-homed host firewall. In this configuration, a host with two NICs connects a trusted network to an untrusted network, but does not employ a screening router. The host acts as a filter to packets passing between the networks and is configured as a strong defense against attacks. This type of host is known as a bastion host. [Figure 2-6](#) shows a dual-homed host firewall configuration.

Screened-Subnet Firewalls

A screened-subnet firewall employs another variation of two NICs with a bastion host. It uses packet filtering routers on the trusted and untrusted network sides, and the host provides proxy services. The screened-subnet architecture also defines a demilitarized zone (DMZ) or perimeter network, which is a third network that lies between the internal trusted network and the external untrusted network as an added layer of protection. [Figure 2-7](#) is an example of a screened-subnet firewall.

Additional means to protect information systems include scrambling the data so that it cannot be read or compromised by an attacker. This approach employs cryptography, which will be discussed in the next section.

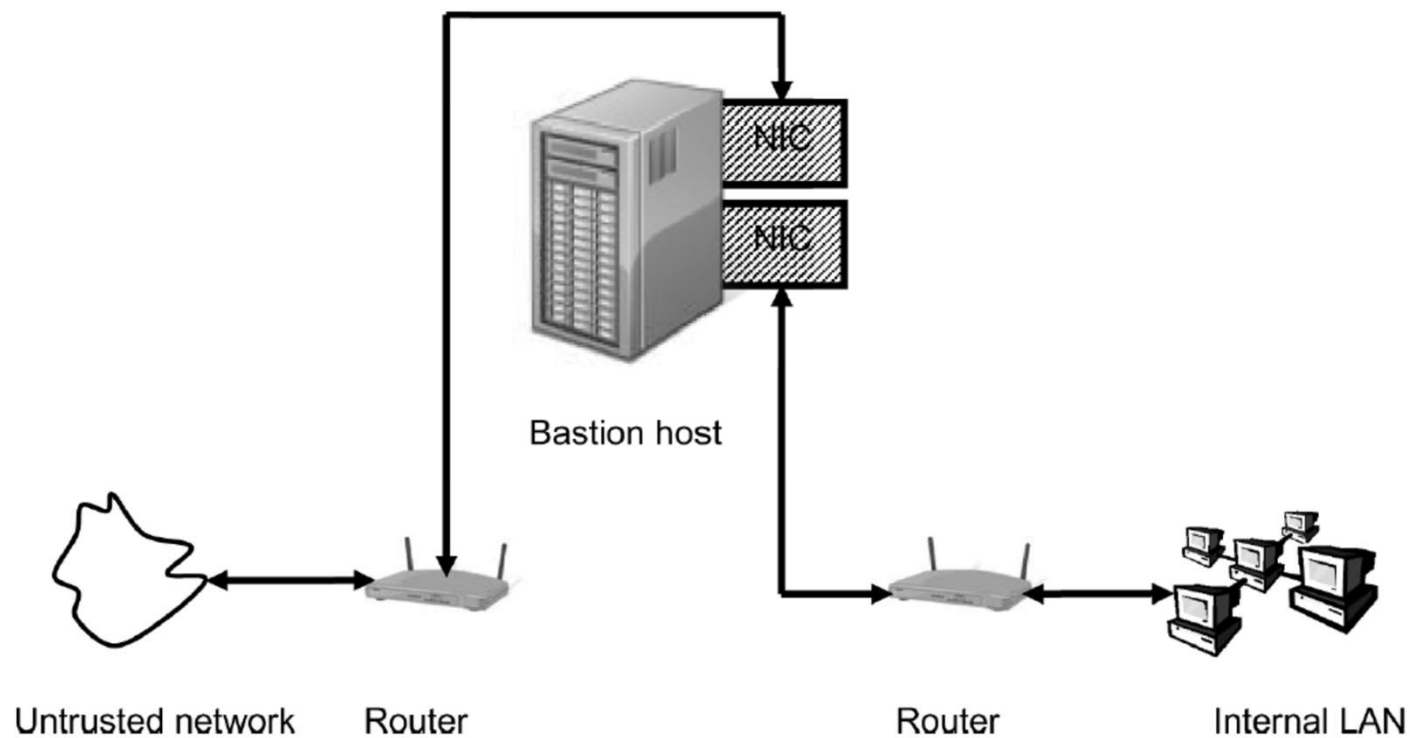


Figure 2-6. Dual-homed host firewall

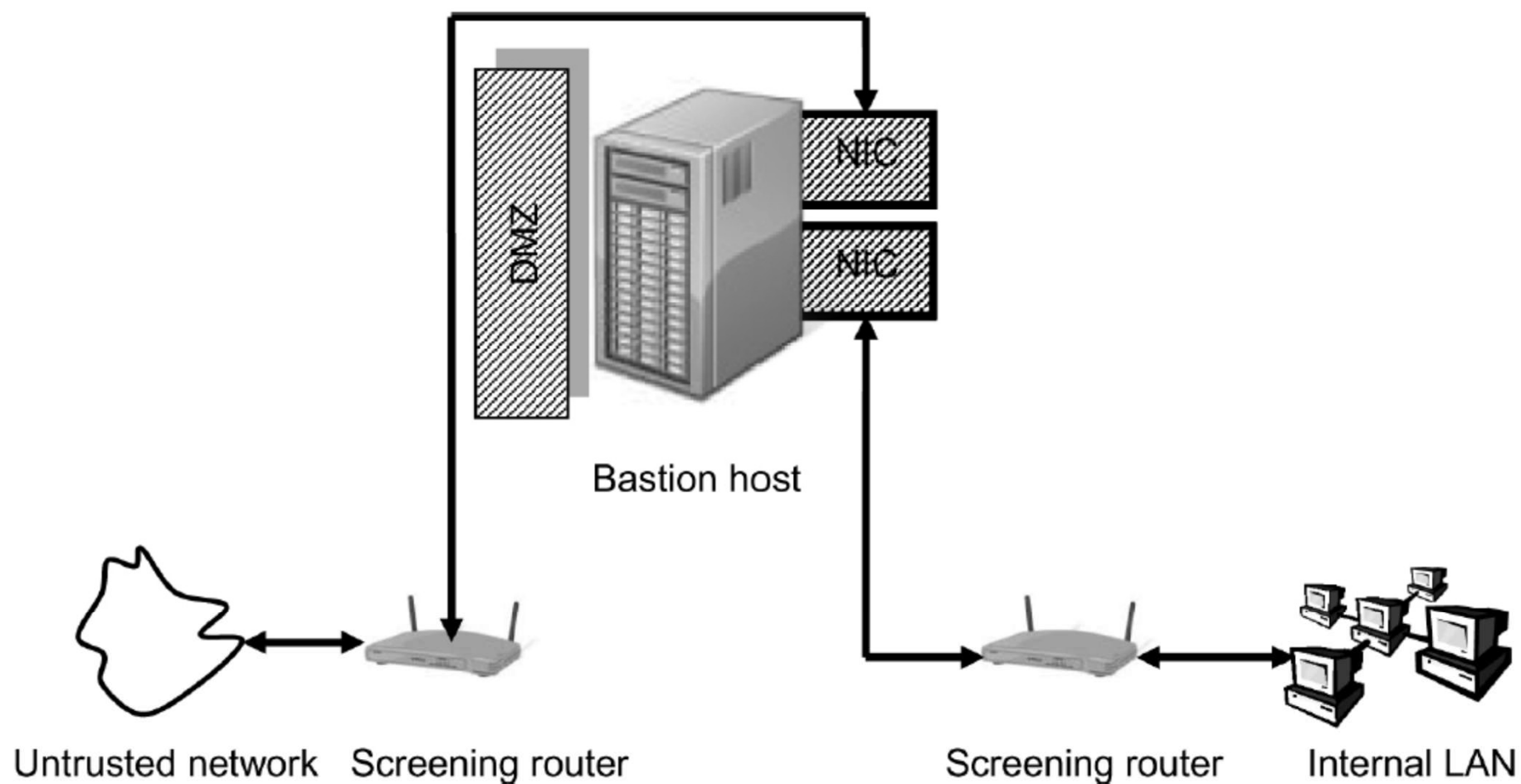


Figure 2-7. Screened-subnet firewall

Cryptography

The purpose of cryptography is to protect transmitted information from being read and understood by anyone except the intended recipient. Cryptography can be used to implement confidentiality, integrity, authentication, and non-repudiation.

The most familiar form of cryptography is secret key or symmetric key cryptography, where the sender and receiver both know a secret key. The sender encrypts a plaintext message with the secret key, and the receiver decrypts the message with the secret key. Thus, the sender and receiver have a shared secret. One of the problems with secret key cryptography is how to securely distribute the secret key used by the sender to the receiver. This distribution might be accomplished with a messenger or by another out-of-band communication means, such as by fax or mail. Out-of-band communications refer to using another means of communication that is different from the means used to send the main message.

A solution to the key distribution problem of secret key encryption came in the development of asymmetric or public key encryption. In asymmetric key cryptography, the receiver holds a private key, and the sender uses a public key to encrypt the message. The public and private keys are related mathematically such that a message encrypted with the public key can be decrypted only with the private key held by the receiver. The public key is made available to anyone who wants to use it, and the private key of the pair is held secret by the receiver. The private and public keys are related, but in the ideal case, they share the characteristic that the private key cannot be derived using knowledge about the public key.

Public key cryptography requires more computations than secret key cryptography and is therefore much slower in data transmission than secret key cryptography. Symmetric and asymmetric key cryptography are discussed in more detail in the following sections.

Symmetric Key Cryptography

In symmetric key cryptography, it is critical that the secret key be kept secure and uncompromised. In an ideal situation, a secret key would be used only once and would not be used in subsequent transmissions. In general, the symmetric key encryption algorithm is known and is available to the public, but the cryptographic system is secure if the secret key or cryptovariable, as it is sometimes called, is kept private and secure. A symmetric key cryptographic system (“cryptosystem”) block diagram is shown in [Figure 2-8](#).

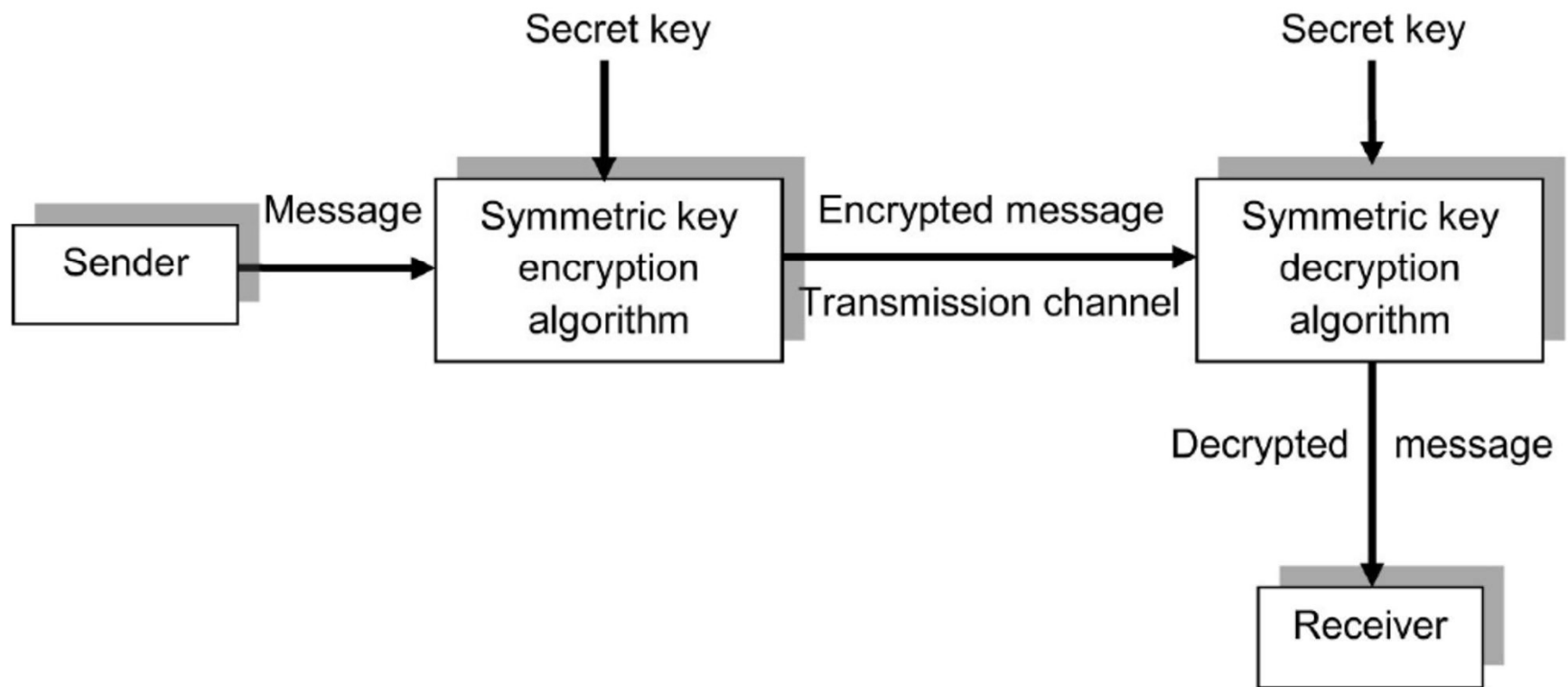


Figure 2-8. A symmetric key cryptosystem

Symmetric key encryption algorithms are fast compared to asymmetric key algorithms and are widely used to securely transmit large volumes of data. One popular symmetric key algorithm is the Advanced Encryption Standard (AES), which is specified in NIST Federal Information Processing Standards (FIPS) Publication 197¹¹. The standard specifies three symmetric key strengths of 128, 192, or 256 bits. AES has been adopted by private and public organizations inside and outside the United States and is widely used in smart cards, routers, and a variety of other applications.

Asymmetric Key Cryptography

As mentioned, asymmetric or public key cryptography uses a public and a private key. The public key can be accessed by anyone desiring to send an encrypted message to the holder of the corresponding private key. The important properties of a properly generated public-private key pair are summarized as follows:

- A message encrypted by one of the keys can be decrypted by the other key of the pair.
- The private key is kept confidential.
- The public key cannot be used to determine the private key.
- The public key cannot decrypt the message that it encrypted.

A typical asymmetric key cryptosystem is given in [Figure 2-9](#).

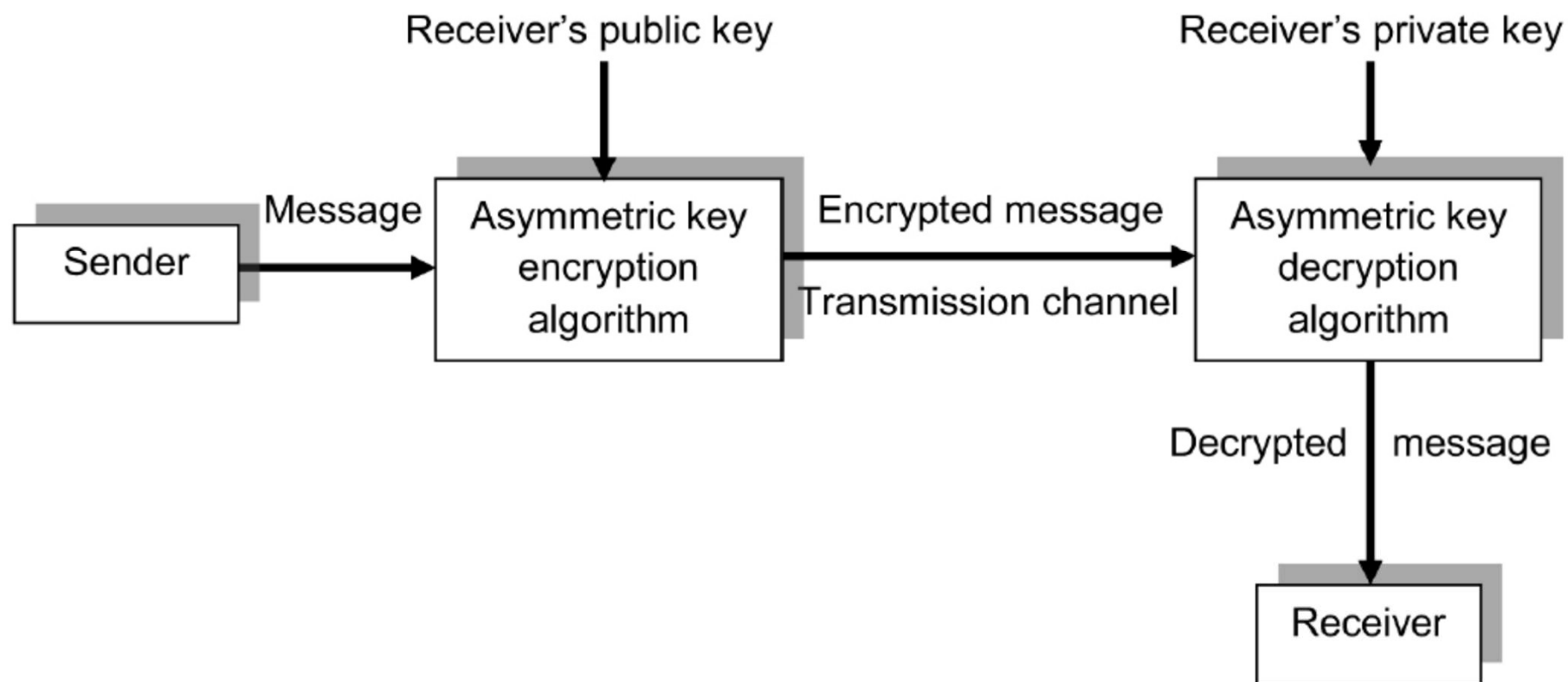


Figure 2-9. An asymmetric key cryptosystem

One of the most popular asymmetric key algorithms is the RSA algorithm, named after its developers, Rivest, Shamir, and Addleman¹². The strength of the RSA algorithm is based on the difficulty of finding the prime number factors of a large number, which would be required to generate the private key from the corresponding public key.

Asymmetric cryptographic key sizes have to be much larger than symmetric key sizes to obtain the same level of security. [Table 2-4](#) lists the equivalent key strengths in bits of symmetric and asymmetric cryptographic systems to obtain the same level of protection through encryption.

An important application of asymmetric cryptography is in generating digital signatures.

Table 2-4. Symmetric vs. Asymmetric Key Sizes

Symmetric key size	Asymmetric key size
80	1024
112	2048
128	3072
192	7680
256	15360
[Source: NIST SP 800-57, <i>Recommendation for Key Management – Part 1: General (Revision 3)</i> , May 2011.]	

Digital Signatures

The NIST Digital Signature Standard (DSS)¹³ defines a digital signature as “the result of a cryptographic transformation of data that, when properly implemented, provides a mechanism for verifying origin authentication, data integrity and signatory nonrepudiation.” A digital signature uses asymmetric key encryption to achieve nonrepudiation of a transmitted message and to authenticate the sender and receiver.

As part of the implementation of a digital signature, a variable-length message is fed into a type of encryption system, known as a hash function, which produces a shorter, fixed length output digital stream, a message digest. The message digest is uniquely bound to the input message, and any change in the input message will result in a change in the hash function output. This characteristic provides integrity checking and is also used to implement non-repudiation. The ideal characteristics of a hash function are:

- It is a one-way function because the original input file cannot be created from the message digest.
- Two files should not have the same message digest.
- The message digest should be calculated by using all of the original input file's data.
- It should not be feasible to find another file with the same message digest, given a file and its corresponding message digest.

The digital signature of a message, M , is accomplished through the following steps:

1. Generate the message digest of M using a valid hash function.
2. Encrypt the message digest with the private key of the sender, and attach it to M .
3. Transmit M with the attached message digest.
4. Decrypt the message digest at the receiver's end by using the sender's public key. Because the public key of the sender is the

only key that can open a file encrypted with the sender's private key, the sender is authenticated.

5. Compute the message digest of M at the receiving end, using the same hash function as the sender.
6. Compare the message digest computed at the receiving end with the message digest transmitted by the sender together with message M. If the two message digests are identical, this verifies that the message was not modified after it left the sender.

Note that in this process, the message itself is not encrypted. [Figure 2-10](#) summarizes the digital signature process.

An important issue that has to be addressed in using asymmetric cryptographic systems is the possibility that an individual, A, would falsely have the name of another person, B, attached to A's public key. Then, any messages sent to B could only be opened and read by A using A's private key. Thus, A would be reading all of B's messages. In order to thwart this kind of attack, an independent third party could be used to certify that a person's public key was actually the key associated with that person. This independent third party is known as a certificate authority and, if presented with the proper credentials, can warrant that an individual's public key is his or her valid public key and can generate a digital certificate to that effect. The certificate contains the subject's name, the subject's public key, the name of the certificate authority, and the period in which the certificate is valid. This certificate is then sent to a repository, which holds the certificates and certificate revocation lists (CRLs) that denote any revoked certificates.

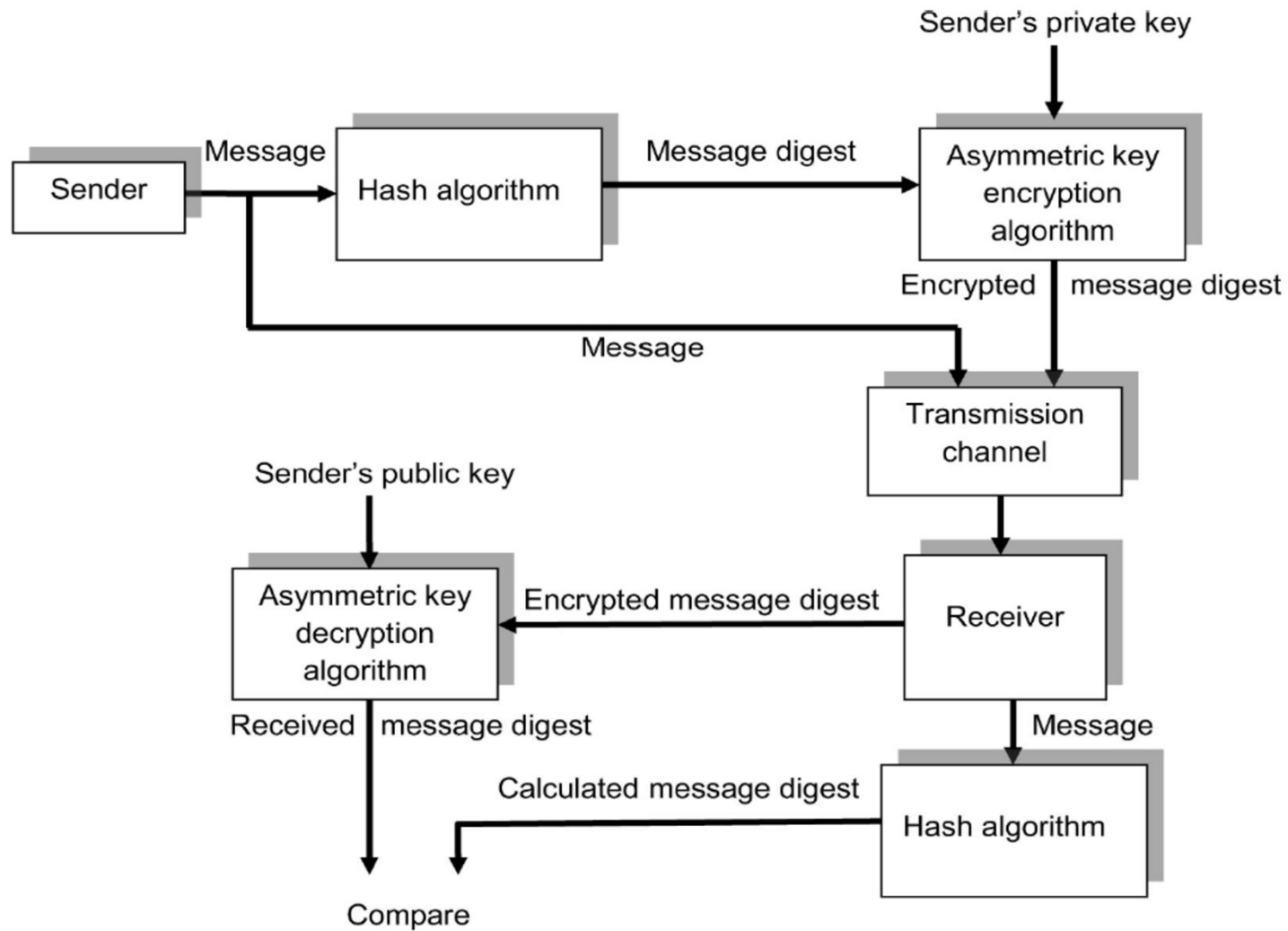


Figure 2-10. The digital signature process

Attacks Against Cryptosystems

The formal term for attacking cryptographic systems is cryptanalysis. In crypt-analysis, an attacker attempts to obtain the original, unencrypted message (plaintext) from the encrypted message (ciphertext). A number of approaches have been developed to perform cryptanalysis, from using mathematic formulations to measuring electronic emissions from chips. The most common attacks are summarized as follows:

- Known plaintext attack – The attacker has access to samples of the unencrypted and encrypted versions of messages and uses this information to attempt to determine the key.
- Ciphertext only attack – The attacker has access to multiple samples of encrypted messages that have been encrypted with the same algorithm and attempts to find the key.
- Man-in-the-middle attack – The attacker intercepts messages being sent between two parties and attempts to decipher them and, possibly, to forward false messages to the parties.

- Replay attack – The attacker intercepts a message and sends it a later time.
- Chosen plaintext attack – The attacker has the ability to select plaintext messages, have them encrypted, and then analyze the results to determine the key.
- Chosen ciphertext attack – The attacker has the ability to select ciphertext messages for trial decryption while having access to the corresponding decrypted plaintext.
- Adaptive chosen ciphertext – The attacker conducts a chosen ciphertext attack but uses the results of one iteration to select the ciphertext to be used in the next iteration.

- Adaptive chosen plaintext – The attacker conducts a chosen plaintext attack but uses the results of one iteration to select the plaintext to be used in the next iteration.
- Differential cryptanalysis – The attacker analyzes ciphertext pairs generated by the encryption of plaintext pairs and attempts to use any differences in the ciphertext pairs to determine the key.
- Linear cryptanalysis – The attacker analyzes ciphertext pairs and their corresponding plaintext pairs to develop a linear approximation to portions of the key.
- Brute force – The attacker tries all possible combination of keys in hope of finding the correct key.

Encryption and digital signatures can be used effectively to transmit sensitive information securely over the Internet. One of the major means of accomplishing this type of transmission is the use of a virtual private network.

Virtual Private Network

NIST Special Publication 800-82¹⁴ defines a virtual private network (VPN) as:

A restricted-use, logical (i.e., artificial or simulated) computer network that is constructed from the system resources of a relatively public, physical (i.e., real) network (such as the Internet), often by using encryption (located at hosts or gateways), and often by tunneling links of the virtual network across the real network.

ANSI/ISA-TR99.00.01-2007¹⁵ gives the following definition of a VPN:

A VPN is a private network that operates as an overlay on a public infrastructure. It contains three components, which are handled at the recipient end of the VPN:

- Authenticity and Authentication – Security measures designed to establish the validity of a transmission, message, originator, or a means of verifying an individual's authorization to receive specific categories of information.
- Integrity – In a formal security mode, integrity is interpreted more narrowly to mean protection against unauthorized modification or destruction of information.
- Confidentiality – Assurance that information is not disclosed to unauthorized persons, processes, or devices.

A secondary component of VPNs is authorization, which encompasses:

- The rights granted to a user to access, read, modify, insert, or delete certain data, or to execute certain programs
- Access privileges granted to a user, program, or process

In other words, the purpose of a VPN is to provide a user with the ability to use a public network, such as the Internet, to transmit and receive information that must be protected from compromise. A typical VPN is illustrated in [Figure 2-11](#).

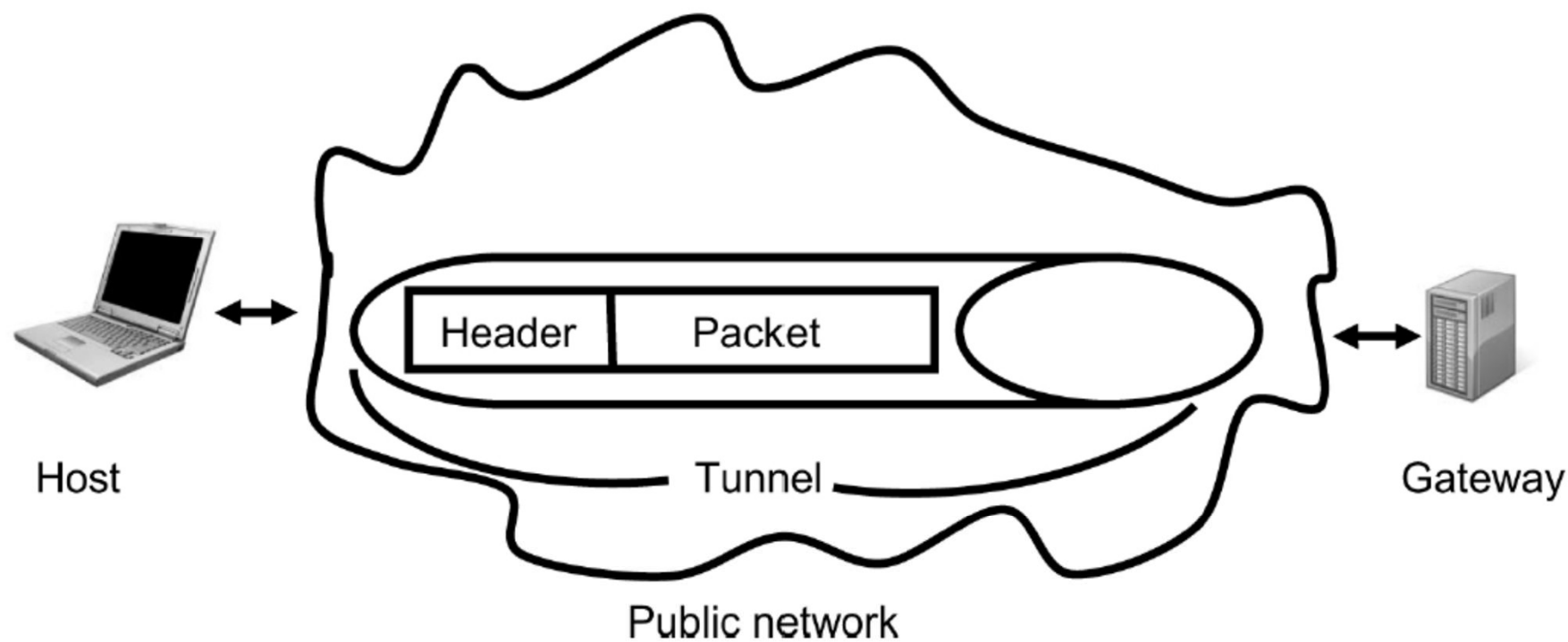


Figure 2-11. A typical virtual private network

There are three general types of VPNs:

- Gateway-to-gateway – Provides secure communications over a public network between two trusted networks, such as between two organizations.
- Host-to-gateway – Also known as a remote access VPN, provides secure communication between a host computer and an organization's network. An example of this type of VPN is a traveling salesman connecting his laptop to the organization's network from a remote location.
- Host-to-host – Enables secure communication between two computers over an untrusted network.

The characteristics of VPNs lend themselves to their use in industrial automation and control systems through their ability to establish secure communications between host systems and controllers over the Internet.

A VPN uses a tunnel through the public network to transmit the data to be protected. Establishing a tunnel, or tunneling, consists of encapsulating packets of a particular VPN protocol inside headers and transmitting the packets over another carrier protocol. The transmission takes place over a logical network connection established between the VPN client and server. The information being sent may be encrypted or not encrypted. For maximum security, the packets should be encrypted using an approved algorithm and a strong key. At the destination host, the reverse procedure takes place and the packets are unencapsulated and decrypted, if necessary. Two of the most popular VPN technologies are the Internet Security Protocol (IPsec) and Secure Sockets Layer (SSL).

IPsec

IPsec operates at the OSI network layer and provides the following two modes of encryption:

- Transport mode – Encrypts the data segment of the packet to be transmitted and does not encrypt the header.
- Tunnel mode – Adds an additional header to the packet and encrypts the entire packet, including the original header.

IPsec operates with two security protocols, Authentication Header (AH) and Encapsulating Security Payload (ESP). AH can provide authentication of the source and integrity of packets and data; however, it does not use encryption. ESP supports encryption along with providing authentication and integrity. Of the two protocols, ESP is more commonly used.

Secure Sockets Layer

The Secure Sockets Layer (SSL) protocol was developed in 1994 by Netscape to provide for secure Internet transactions. SSL encrypts the packet contents and authenticates the server to the client using digital signatures and digital certificates. The Internet Engineering Task Force (IETF)¹⁶ modified SSL 3.0 to produce the Transaction Layer Security (TLS) protocol, which has evolved to version 1.2¹⁷. SSL and TLS are popularly used to secure Internet HTTP communications and are known as HTTP secure (HTTPS). Information on applying TLS is given in NIST SP 800-52¹⁸.

Summary

Chapter 2 has reviewed some of the basic tenets of information system security with the objective of developing a foundation for applying these methods, with appropriate adjustments, to harden and protect industrial automation and control systems. Many of the attack types reviewed in this chapter can be used against industrial automation and control systems in order to cause malfunctions, cause physical and economic damage, or even threaten lives. The countermeasures and techniques presented in Chapter 2, properly applied, have the ability to improve the security posture of the systems controlling the nation's infrastructure and manufacturing facilities and thereby prevent or mitigate disruptive and damaging occurrences.

With the security concepts of this chapter in mind, Chapter 3 will explore the similarities and differences between industrial automation and control system characteristics and requirements and those of IT systems.

